

Non-Graded Project: Simulate and Respond to a Multi-Layered Breach

Learning Objectives

By the end of this activity, learners will be able to:

- Develop a standards-aligned incident response plan for a complex data breach using ISO 27035 and NIST SP 800-61.
 - Coordinate incident response tasks and roles using a project management tool.
 - Analyze control gaps and audit-readiness deficiencies exposed by a security incident.
-

- Formulate a strategic, post-breach improvement roadmap to enhance organizational resilience.
- Synthesize technical analysis and strategic recommendations into a concise executive briefing.

Description

Imagine you are the CISO for a mid-sized fintech firm that has just suffered a sophisticated ransomware attack, compromising both customer data and internal operational systems. The board needs a clear response plan, an assessment of the damage, and a strategy to prevent recurrence. Your task is to lead the response, analyze the governance failures that allowed the breach, and present a clear path forward.

In this project, you will step into the CISO role to manage this crisis. You will apply the integrated ISO and NIST principles from the course to a high-stakes, real-world scenario. You will use AI and project management tools to draft an incident playbook, coordinate your response team, identify the underlying control gaps in your ISMS, and create a roadmap for improvement. Your final deliverable will be an executive briefing that demonstrates your ability to manage a crisis and strengthen cybersecurity governance under pressure.

This challenge provides a hands-on opportunity to apply your knowledge in a dynamic, simulated environment, using modern tools to drive an effective cybersecurity response.

Structure of the Project

Tools:

ChatGPT or another generative AI tool

ClickUp

Microsoft 365 Excel Copilot

Scenario

"FinSecure Capital," a fast-growing fintech firm providing digital wealth management services, has detected a major security breach. Ransomware has encrypted critical servers, and there is evidence that the attackers have exfiltrated sensitive customer financial data. As the CISO, you are responsible for leading the incident response (IR) team, assessing the impact on your ISO 27001 certification and NIST CSF alignment, and reporting to executive leadership.

Objective

Your goal is to use AI and collaboration tools to manage the incident response process and produce a comprehensive post-incident executive briefing. This exercise will test your ability to apply the course's 16-step governance lifecycle under duress, moving from reactive response to proactive improvement.



Follow these steps to do this project

Step 1: Draft an Initial Incident Response Plan Use your AI tool to quickly generate a structured response plan based on industry best practices.

Prompt Idea: "Act as a CISO for a fintech firm. A ransomware attack has encrypted servers and exfiltrated customer data. Using NIST SP 800-61 and ISO 27035 as a guide, draft an initial incident response plan. The plan should include phases for: Containment, Eradication, and Recovery. For each phase, list 3-4 critical action items."

Step 2: Coordinate the Response Team Use a project management tool to translate the plan into actionable tasks and assign roles.

Action: In ClickUp, create a new project called "Incident Response." Create tasks based on the action items from your AI-generated plan (e.g., "Isolate affected network segments," "Activate backup recovery protocols," "Engage external forensics firm"). Assign these tasks to notional roles (e.g., IT Ops Lead, Security Analyst, Legal Counsel).

Step 3: Analyze Control Gaps and Audit Impact Use an AI-powered spreadsheet tool to analyze how the breach impacts your compliance and risk posture.

Action: Open Microsoft Excel. Create a simple table with columns: "Attack Stage," "Failed Control (ISO 27001)," "Related NIST CSF Function," and "Impact on Audit."

Prompt Idea for Excel Copilot: "Based on a ransomware attack that involved a phishing email and lateral movement, populate this table. For the 'Attack Stage' column, use 'Initial Access' and 'Privilege Escalation.' Map these stages to likely failed ISO 27001 Annex A controls and the corresponding NIST CSF functions. Describe the audit impact, such as 'Major non-conformity' or 'Evidence of ineffective control'."

Step 4: Formulate a Post-Breach Improvement Roadmap Use your AI tool to brainstorm strategic recommendations to prevent future incidents.

Prompt Idea: "Based on the incident analysis, generate a 3-point improvement roadmap for FinSecure Capital. For each point, recommend a specific action, the resources needed, and a KPI to measure its success. Recommendations should focus on technical controls, **employee training, and governance processes.**"

Step 5: Compile the Executive Briefing Organize all generated outputs into a single, professional document.

Organize information following this structure for peer review

Title Page: Post-Incident Executive Briefing, Your Name, Date.

Section 1: Incident Overview & Response Plan: A summary of the attack and the initial response plan drafted in Step 1.

Section 2: Response Coordination: A screenshot or summary of the task board from ClickUp.

Section 3: Governance Gap Analysis: The completed table from Excel showing the failed controls and audit impact.

Section 4: Strategic Improvement Roadmap: The 3-point roadmap for preventing future incidents.

Section 5: Concluding Recommendation: Write one critical, actionable recommendation for the FinSecure Capital board to prioritize in the next quarter.

Instructions for Documenting and Sharing the Project for Peer Review



1. Document the Project

Use word processing software to create your Post-Incident Executive Briefing.

Ensure all sections of the project document structure are completed.

Proofread and edit your report for clarity and accuracy.



2. Share the Project

Save your report in PDF format.

Upload your document to the “Peer Review” area in the course shell.

Provide a brief description of your project in the submission post.



3. Peer Review

Review the projects submitted by your peers.

Provide constructive feedback and comments on their work.